title: Device-code phishing: the Conditional Access check to do before you block anything
date: 2026-10-28
summary: Device-code phishing gets tokens without a stolen password. A short review of sign-in logs and the device-code flow policy tells you whether blocking it is safe for your tenant.
draft: false

Short answer

Device-code phishing tricks a user into entering a short code on the real Microsoft sign-in page. The attacker gets a token for the account, and the password is never stolen. Blocking the device-code flow in Conditional Access is a strong control, but only after you know which apps in your tenant still depend on it.

What is known

- Microsoft's Security Blog published research on 22 Sep 2026, titled *Unmasking EvilTokens*, which describes device-code phishing used to obtain tokens. This is the source for the technique.
- The attack works because the device-code flow is designed for devices without a browser. A user who is tricked into completing it signs in the attacker's session.

Confirmed: the technique and the Microsoft research exist.
Likely: users who are asked to enter a code they did not request are the main target.
Unclear: how many tenants have seen this in practice, and which lures were used. Treat any specific number as unverified.

Why this matters for your tenant

- Phishing-resistant MFA does not stop this on its own if the user completes the flow.
- Legacy tools, some scanners and some printers can depend on device-code sign-in. Blocking it without a check can stop real work.
- The sign-in log shows device-code sign-ins, so you can see the real usage before you decide.

What I would check this week

1. **Usage first:** in **Entra admin center → Monitoring & health → Sign-in logs**, filter by authentication protocol or flow where your portal exposes it, and review device-code sign-ins for the last 30 days. Note which applications and users appear.
2. **Policy state:** in **Protection → Conditional Access → Policies**, check whether any policy already blocks the *Device code flow* for users. Review it with the policy owner.
3. **Exceptions:** list every app or user that legitimately needs the flow. Each exception needs an owner.
4. **Block in report-only mode:** create or edit the policy for a test group and review the report-only results before you enforce it.
5. **Tell the helpdesk:** a user who is asked for a code by a stranger should report it, not enter it.

Risk and rollback

- **Risk of blocking:** Medium if you block without checking. Some business tools stop working immediately.
- **Risk of not blocking:** Medium to high for users who can be lured with a code request.
- **Rollback:** set the policy to report-only or disable it. Document who approved the change.

Verification

- The sign-in log review for 30 days is recorded, with the list of applications using the flow.
- The report-only results show no unexpected impact on the test group.
- Each exception has a named owner and a review date.

Source: Microsoft Security Blog, 22 Sep 2026, as summarised in the weekly briefing on this site. Read the original before you rely on details.